

Introduction

An organization's security policy framework creates the foundation for its cybersecurity efforts. Technology and business leaders use policies, standards, guidelines, and procedures to communicate security objectives, prescribe required actions, and set forth best practices for use throughout the organization. This guidance is crucial to many different groups of stakeholders, ranging from the technology professionals who design and implement systems to the end users who make routine security decisions on a daily basis.

The security policy framework consists of four different types of documents, each of which serves a different purpose in an organization's cybersecurity program:

- **Policies** are high-level statements of an organization's security objectives and the principles that the organization will follow. Policy documents should be written using high-level language that avoids mentioning specific implementation details. As a result, they should be lasting documents that require only infrequent revision. For example, an organization might include a statement in its security policy that the Chief Information Security Officer bears overall authority and responsibility for meeting the organization's cybersecurity objectives. Compliance with policies is mandatory.
- **Standards** provide more detailed security requirements for specific situations. Standards may cover elements of software and system design, configuration, or operations and will often contain technical detail. For example, an organization might create a standard for the configuration of Windows Server systems that includes the detailed security settings that they will use to achieve compliance with the standard. Compliance with standards is mandatory.
- **Guidelines** offer suggested best practices for achieving security objectives. They include recommendations from subject matter experts on ways that employees may achieve security objectives, but those recommendations are not mandatory. They merely offer a suggested approach.
- **Procedures** set forth a step-by-step process for carrying out an activity, offering guidance to employees on how to achieve a specific goal. For example, the organization might have a new hire account generation procedure that specifies the steps involved in onboarding a new employee. Compliance with procedures may be either mandatory or optional, depending upon the nature of the procedure and the policy of the organization.

In this lab, you will learn to apply the security policy framework to an access control environment. In the first part of the lab, you will review a set of best practices for password policies and then review a real-world password policy. You will then have the opportunity to offer suggestions for revising the policy to better align with those best practices. In the second part of the lab, you will review a security

configuration standard and learn how to apply it to production systems. Finally, if assigned by your instructor, you will write a procedure for achieving an access control objective.

Lab Overview

This lab has two parts, which should be completed in the order specified.

1. In the first part of the lab, you will review a set of best practices for password policies and then review a real-world password policy. You will have the opportunity to offer suggestions for revising the policy to better align with those best practices.
2. In the second part of the lab, you will review a security configuration standard and learn how to apply it to production systems.

Finally, if assigned by your instructor, you will complete a series of challenge exercises that allow you to use the skills you learned in the lab to conduct independent, unguided work - similar to what you will encounter in a real-world situation.

Learning Objectives

Upon completing this lab, you will be able to:

1. Evaluate a security policy against best practices.
2. Understand the role of policies, standards, procedures, and guidelines in the security policy framework.
3. Identify the element of the security policy framework that best meets an objective.
4. Understand the process of applying a security configuration standard to a system.

Deliverables

Upon completion of this lab, you are required to provide the following deliverables to your instructor:

- Identify the best practices met by the Michigan password policy
- Suggest revisions for the Michigan password policy
- Describe whether the Michigan password policy is best titled as a policy or as another element of the security policy framework
- Describe the Center for Internet Security consensus process
- Identify the section of the CIS standard that implements password composition requirements
- Identify whether the CIS standard satisfies, violates, or does not address each of the NIST best practices and the relevant recommendation number
- Challenge Exercise (if assigned)

Guided Exercises

Note: In this section of the lab, you will follow a step-by-step walk-through of the objectives for this lab to produce the expected deliverable(s).

1. **Review** the [Common Lab Tasks for Theory Labs document](#).

Frequently performed tasks, such as recording your answers and downloading your Lab Report, are explained in the Common Lab Tasks for Theory Labs document. You should review these tasks before starting the lab.

2. **Proceed** with **Part 1**.

Part 1: Evaluate a Security Policy

Note: The current National Institute for Standards and Technology (NIST) guidance for the use of passwords introduced some major changes to the best practices that cybersecurity professionals have historically followed. If you completed these labs in order, you may recall from Lab 1 that you reviewed NIST SP 800-63b, *Authenticator and Verifier Requirements*, which includes these standards. The current NIST best practices include:

- Passwords should be at least 8 characters in length.
- Passwords should be permitted to be up to 64 characters in length.
- Users should not be prompted to provide a password hint.
- Passwords should not be composed of dictionary words.
- Passwords should not include repetitive or sequential characters or context-specific words.
- Passwords may not be passwords included in previous breaches.
- Passwords should not be subject to other complexity rules.
- Passwords should not be set to expire arbitrarily.
- Authentication systems should provide guidance on the strength of selected passwords.
- Authentication systems should limit the number of failed consecutive logins for an account.

In this part of the lab, you will review a real-world access control policy and determine whether it complies with these best practices. You will also suggest changes to the policy that bring it into compliance with the new best practices.

1. **Download** and **review** the [policy document](#).

This is a sample password policy provided by the State of Michigan for use as a template in designing password policies for state government agencies.

2. **Evaluate** the policy document against the NIST best practices summarized above. **Identify by number** which, if any, of the eight best practices the policy satisfies. For each practice that you identify, **provide a reference** to the statement in the policy that aligns with that best practice.
3. **Suggest** how you would revise the policy to directly align with the standards. **Provide specific statements** that you would add/modify in the policy.
4. **Describe** whether this document is best titled as a policy or whether it would be better described using another element of the policy framework.

Part 2: Review a Security Configuration Standard

Note: Security configuration standards are often very detailed documents containing granular implementation details for configuring systems and devices. Creating these standards is time-consuming work and organizations should consider leveraging the work already performed by industry groups.

The Center for Internet Security ([cisecurity.org](https://www.cisecurity.org)) is a cybersecurity organization that uses a collaborative process to create consensus standards for many different operating systems and applications. Organizations may choose to use the Center for Internet Security standards as the baseline for their own configuration standards. They may either simply adopt the Center's standards as is, or write their own document that notes changes from the Center's standard.

In this lab, you will review one of these consensus security standards and describe how you would implement it in your environment.

1. **Navigate** to <https://www.cisecurity.org/> and locate the Center's benchmarks for configuring Windows Server systems.

You will need to register to create an account on the Center's website to download their standards. There is no fee required to complete this process.

2. **Review** the "Consensus Guidance" section of the document.

3. **Describe** the process that the Center uses to ensure that its standards represent the consensus of the cybersecurity community.
4. **Locate and review** the section of the standard that implements password composition requirements.
5. **Identify** the section of the recommendations that achieves this goal.
6. **Compare** the configuration suggested in the policy to this subset of the NIST best practices that you reviewed in Part 1 of this lab:
 - Passwords should be at least 8 characters in length.
 - Passwords should not include repetitive or sequential characters or context-specific words.
 - Passwords should not be subject to other complexity rules.
 - Passwords should not be set to expire arbitrarily.
 - Authentication systems should limit the number of failed consecutive logins for an account.
7. For each of the five best practices in the previous step, **classify** the practice as:
 - Satisfied (indicate recommendation number that achieves the best practice)
 - Violated (indicate recommendation number that violates the best practice)
 - Not addressed

Challenge Exercise

Note: The following scenario provided to allow independent, unguided work, similar to what you will encounter in a real situation.

For this section of the lab, you should consider a security standard that you are familiar with from your employment, academic institution, and/or personal life. If you do not have a security standard that you are familiar with, use a search engine to locate a standard used by a government agency or educational institution.

Identify a set of industry best practices covering the same area as the standard you selected. You may choose to use standards published by the Center for Internet Security, the National Institute for Standards and Technology, a vendor, or other sources.

Select three specific statements included in the standard that you drew from your own experience that are covered by the industry best practice document that you selected. For each of these three statements:

- **Identify** the section of your standard.
- **Identify** the section of the industry best practices that covers the same topic.
- **Identify** whether the standard you selected satisfies or violates the industry best practice.
- **Provide** a rationale for your conclusion.